의료기기 사이버보안 요구사항 시험기준 적용 명세서

신청기업	㈜더픽트
품 목 명	D2AEXA1
제 품 명	방사선 치료 환자를 위한 DIBH 호흡 분석 및 분류 시스템 'DIBH-Flow'
모 델 명	DIBH-Flow

1. 제품사양

구분		사 양
품 목 명		D2AEXA1
제 품 명		방사선 치료 환자를 위한 DIBH 호흡 분석 및 분류 시스템 'DIBH-Flow'
모 델 명		DIBH-Flow
버 전		1.0
제 조 사		㈜더픽트
하드웨어	PCB 정보	Samsung Galaxy Tab S6 메인보드 기반
	Main MCU	Qualcomm Snapdragon 855 Octa-Core Processor
	외부 Memory	LPDDR4X RAM (8GB)
	Storage	UFS 3.0 내장 저장장치
	무선통신	Wi-Fi 802.11 a/b/g/n/ac, Bluetooth 5.0, GPS
	유선통신	USB Type-C (USB 3.1 Gen1)
	외부 인터페이스	USB Type-C, POGO Pin 키보드 커넥터, microSD 슬롯
	내부 인터페이스	MIPI DSI(Display), MIPI CSI(Camera), I2C, SPI, UART
소프트웨어	소프트웨어기능	방사선 치료 환자를 위한 DIBH 호흡 분석 및 분류 시스템
	개발 언어	React, Vite, JavaScript/JSX
OS 종류		Android
펌웨어 버전		1.0
업데이트 방식		USB

2. 통신모듈

2.1. 무선통신

구분	시스템 사양		
Bluetooth	표준	Bluetooth 5.0 BLE	
	비표준		
	암호방식 및 수준	*보안통신, 보안모드1/보안레벨3*	
	통신모듈	모델번호	SM-T860
		제조사	SAMSUNG
		펌웨어 버전	Andriod 12

2.2. 유선통신

구분	시스템 사양	
USB (Type-C)	표준	USB 3.1 Gen 1 (Type-C)
	암호방식 및 수준	해당없음 (데이터 통신 기능을 사용하지 않음)

3. 운영체제 정보

구분	시스템 사양	
Android	OS명	Android
	버전	12

4. 소프트웨어 정보

구분	구분	시스템 사양
DIBH Flow	소프트웨어 유형 (펌웨어, 범용 OS 기반 애플리케이션, 모바일 앱 등)	모바일 앱
	개발 플랫폼(언어)	React 18, Vite 6, JavaScript/JSX
	적용 SDK 버전(MCU 적용)	Capacitor CLI 8.3.1 / @capacitor/core 8.3.1 / @capacitor/android 8.3.1
	3rd Party 라이브러리 사용 여부 및 세부	sql.js 1.14.1 (WebAssembly SQLite) — IndexedDB에 영속화 React 18.2.0, react-router-dom 7.2.0, @tanstack/react-query 5.90.16 react-hook-form 7.54.2, zod 3.24.2, recharts 2.15.1, Radix UI, framer-motion 12.4.7, sonner 2.0.1, tailwindcss 3.4.17
	통신 모듈 SW 버전 (적용 시)	해당없음 — 통신 모듈 미적용
	업데이트 방식	수동 설치 — 제조사가 배포한 APK 파일을

		USB 등 폐쇄 매체로 전달하여 Android 패키지 관리자로 수동 설치. FOTA·업데이트 서버 미사용

5. 데이터 정보 (해당시 작성)

5.1. 수집데이터

수집경로	데이터
Android 파일 피커 (로컬 저장소 / USB	호흡 신호 데이터 파일 (CSV / VXP 형식 — 시간 및 힘(Force, N) 시계열)

5.2. 저장데이터

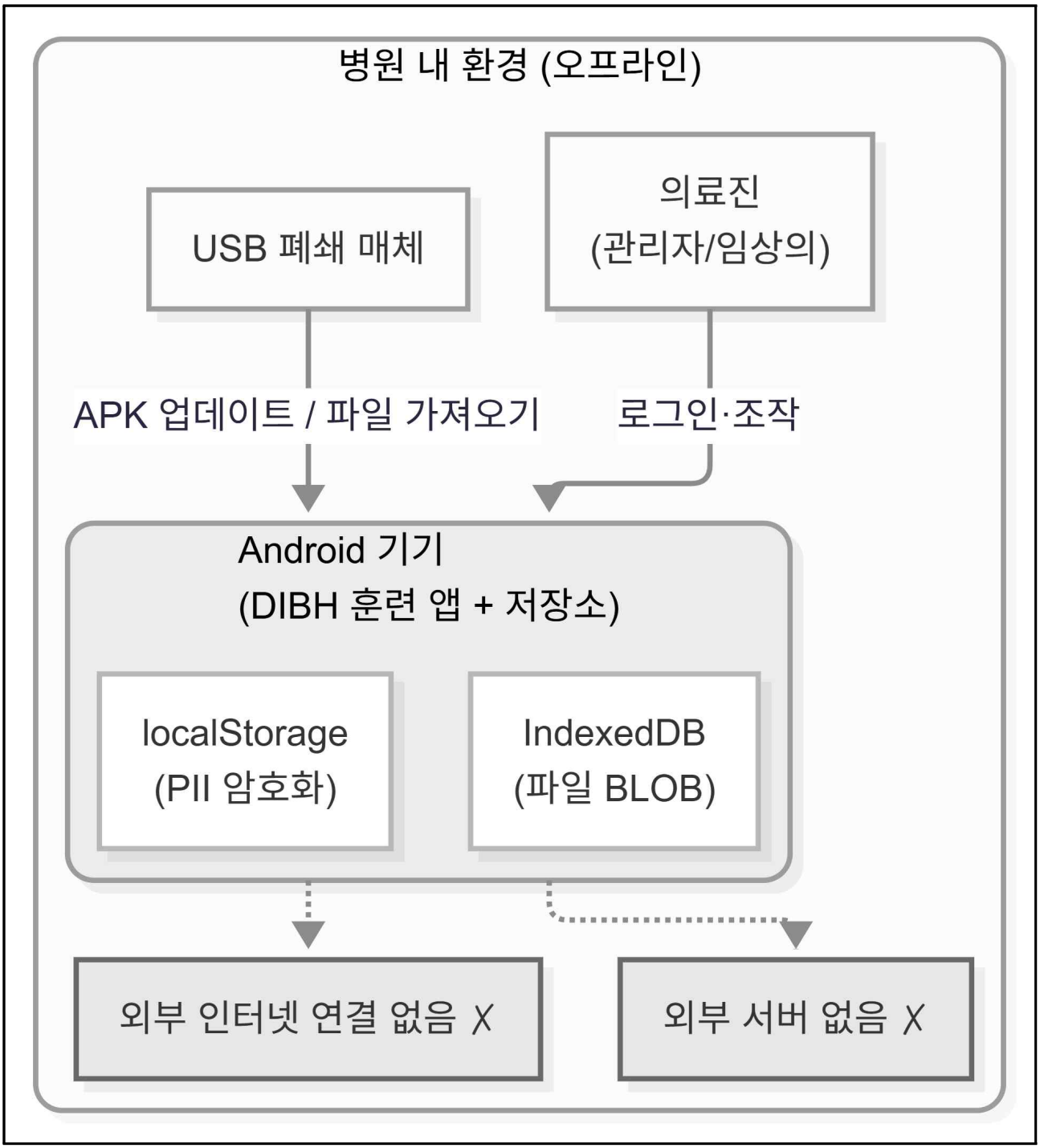
저장방법	데이터
AES-256-GCM 암호화 저장 (localStorage)	환자 개인식별정보(PII): 이름, 생년월일, 환자 코드
PBKDF2-SHA256 단방향 해시 저장 (100,000회 반복 + 16바이트 솔트)	사용자 계정 비밀번호
평문 저장 (localStorage)	훈련 세션 정보, 캘리브레이션 결과, 사용자 계정 메타데이터(역할·잠금 상태 등), 감사 로그 (최대 10,000건, 추가 전용)
SQLite WASM + IndexedDB (sql.js)	호흡 파일 BLOB 원본, SHA-256 무결성 해시, 환자 메타데이터

5.3. 전송데이터

전송 구간	데이터
해당없음	완전 오프라인 운영 — 앱 실행 중 외부 네트워크 전송 기능 없음. 모든 데이터는 기기 내부에 저장

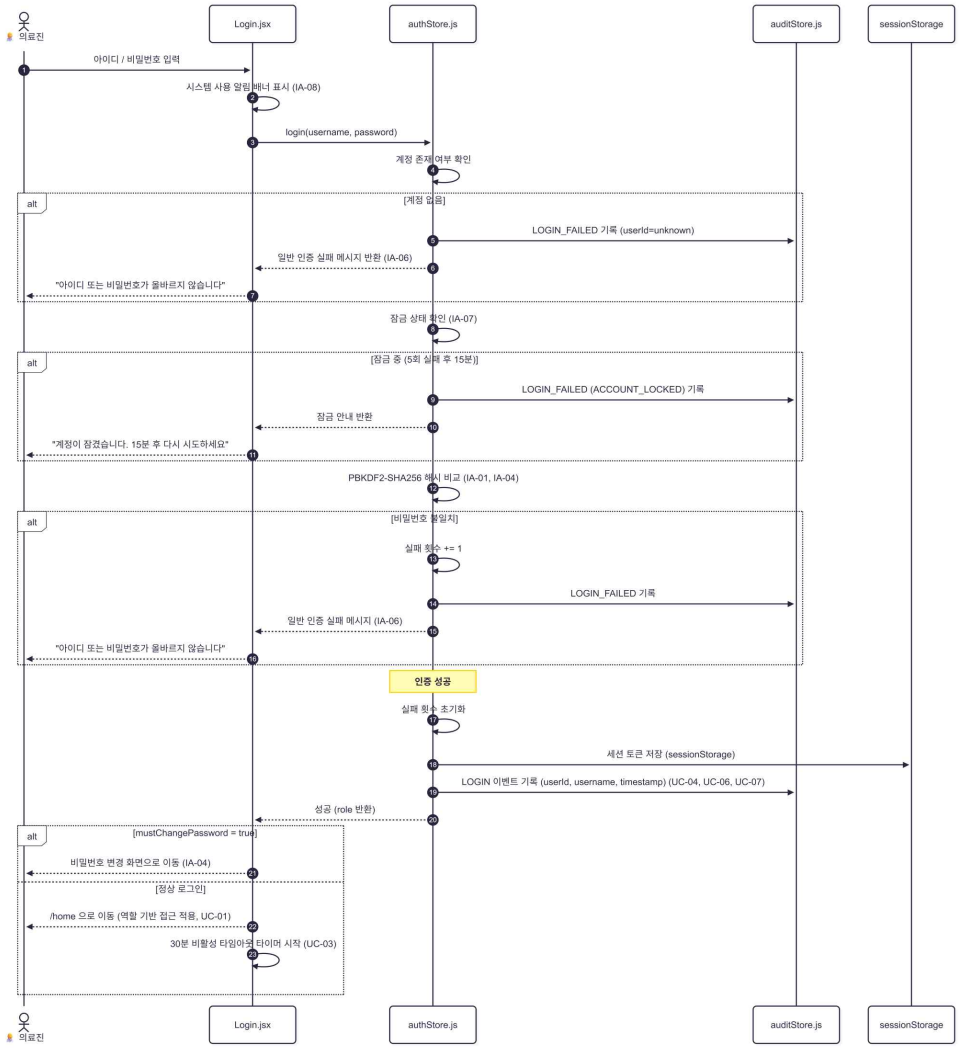
6. 기기 운영환경

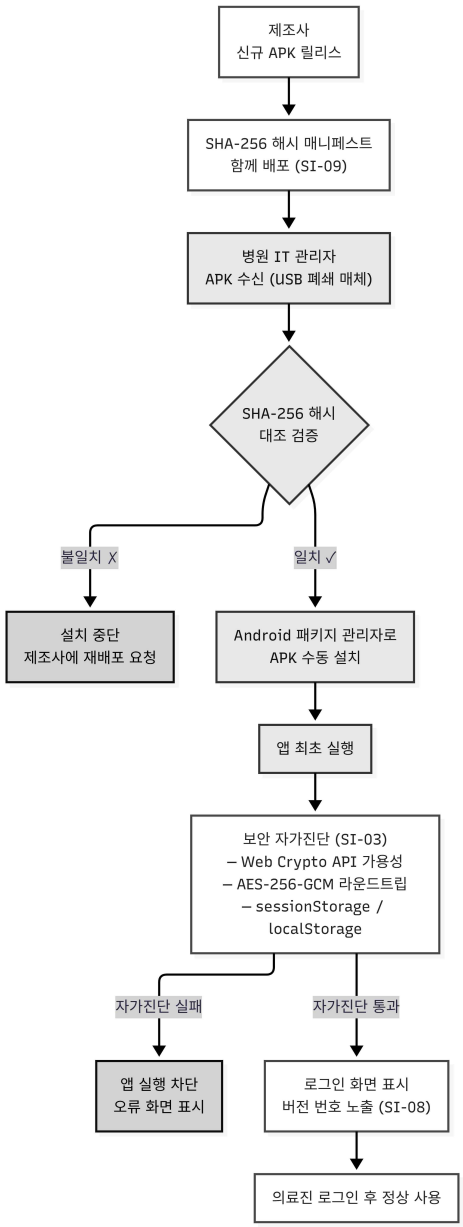
6.1. 기기 운영환경 (네트워크 구성도)



본 제품은 외부 서버 또는 네트워크 연결 없이 단일 Android 기기에서 완전히 독립 실행됩니다.

6.2. 기기 운영 절차

구분	통신 절차 플로우
사용자 인증 또는 기기 간 인증	
데이터 전송 (해당없음)	외부 네트워크 데이터 전송 기능 없음 — 완전 오프라인 앱

구분	통신 절차 플로우
업데이트 절차	1 제조사가 신규 APK 파일 및 SHA-256 해시 매니페스트를 배포 2 병원 관리자가 APK를 USB 등 폐쇄 매체로 Android 기기에 전달 3 관리자가 SHA-256 해시를 매니페스트와 비교하여 무결성 확인 4 Android 패키지 관리자로 APK 수동 설치 5 앱 최초 실행 시 보안 자가진단(Web Crypto 가용성·암호화 라운드트립) 수행 6 로그인 화면 하단에 새 버전 번호 표시 

7. 의료기기 사이버보안 요구사항 체크리스트

<의료기기 사이버보안 특성 기재>

1) 사용되는 통신 기술: *해당없음 (현재 버전 기준 외부 유·무선 통신 기능 없음)*

2) 사용 환경: *병원 내 사용*

3) 공용 네트워크망 사용여부: *N*

사이버보안 요구사항			적용여부	적합성 입증 방법
식별 및 인증 (IA)	IA-01	사용자 식별 및 인증	*적용*	*`authStore.js` — PBKDF2-SHA256 해시 기반 로그인; `Login.jsx` — 로그인 UI 구현*
	IA-02	계정 관리	*적용*	`AdminAccounts.jsx` — 관리자 전용 계정 관리 페이지; `authStore.js` UserStore
	IA-03	식별정보 관리	*적용*	`authStore.js` generateId() — 각 계정에 타임스탬프+난수 기반 고유 ID 부여
	IA-04	인증정보 관리	*적용*	`authStore.js` — mustChangePassword 플래그로 초기 비밀번호 강제 변경; PBKDF2-SHA256 단방향 해시 저장

사이버보안 요구사항			적용여부	적합성 입증 방법
	IA-05	비밀번호 강도 설정	*적용*	passwordUtils.js — 최소 8자, 대문자·소문자·숫자·특수문자 포함 필수
	IA-06	인증정보에 대한 피드백	*적용*	Login.jsx — type="password" 마스킹; 인증 실패 시 원인 비구분 일반 오류 메시지 반환
	IA-07	연속적인 로그인 시도 실패 시 로그인 제한	*적용*	authStore.js — 5회 연속 실패 시 15분 계정 잠금
	IA-08	시스템 사용 알림 메시지	*적용*	Login.jsx UsageNoticeBanner — 로그인 완료 전 시스템 사용 조건 고지 배너 표시
사용 통제 (UC)	UC-01	권한 부여	*적용*	src/pages/index.jsx AdminRoute — admin 역할만 /admin/* 접근 허용; clinician은 환자·훈련 기능만 접근
	UC-02	모바일 코드 사용 통제	*적용*	index.html — CSP 메타태그 설정;

사이버보안 요구사항			적용여부	적합성 입증 방법
				vite.config.js — 개발 서버 CSP 헤더 설정
	UC-03	세션 잠금	*적용*	src/context/AuthContext.jsx — 30분 비활성 시 자동 세션 종료 (mousedown·keydown·touchstart·scroll 이벤트로 타이머 리셋)
	UC-04	감사기록 생성	*적용*	auditStore.js — 로그인·계정 변경·환자 CRUD·파일 업로드·분석·캘리브레이션 등 전 이벤트 기록
	UC-05	감사 처리 실패 대응	*적용*	auditStore.js writeAuditLog — 기록 실패 시 예외 전파 (묵음 처리 안 함)
	UC-06	타임스탬프	*적용*	UC-06: 모든 감사 로그 항목에 timestamp: new Date().toISOString() (ISO 8601) 기록
	UC-07	부인 방지	*적용*	UC-07: 모든

사이버보안 요구사항			적용여부	적합성 입증 방법
				감사 로그 항목에 userId, username 포함 — 행위자 식별 가능
시스템 무결성 (SI)	SI-01	통신에 대한 무결성 보장	*미적용*	오프라인 전용 — 외부 통신 기능 없음 (미적용 사유 참조)
	SI-02	악성코드로부터 보호	*미적용*	SaMD 예외 — 브라우저 샌드박스·CSP 및 호스트 OS 보안에 의존 (미적용 사유 참조)
	SI-03	보안 기능 검증	*적용*	main.jsx securitySelfCheck — 앱 시작 시 Web Crypto API 가용성, AES-256-GCM 암호화 라운드트립, sessionStorage/localStorage 동작 검증
	SI-04	소프트웨어 및 정보에 대한 무결성 점검	*적용*	breathingFileRepository.js — 파일 업로드 시 SHA-256 해시 저장; 분석 실행 전 재검증하여 위변조 탐지

사이버보안 요구사항			적용여부	적합성 입증 방법
	SI-05	입력값 검증	*적용*	Zod 스키마 — 모든 폼 입력 유효성 검사; 파일 크기·형식 제한; React DOM 기본 XSS 방지; sql.js 파라미터화 쿼리로 SQL 인젝션 방지
	SI-06	오류 시 사전 결정된 상태로 출력	*미적용*	자동화된 치료 프로세스에 연결되지 않는 SaMD — 해당없음 (미적용 사유 참조)
	SI-07	오류 처리	*적용*	모든 사용자 대면 오류 메시지 일반화 처리; 내부 스택 트레이스는 console.error 로만 출력
	SI-08	업데이트	*적용*	__APP_VERSION__ — UI 하단 버전 표시; 업데이트 절차 사용자 설명서(docs/user-manual-security.md) 기술
	SI-09	업데이트에 대한 진본성 및 무결성 검증	*적용*	각 릴리스에 SHA-256 해시

사이버보안 요구사항			적용여부	적합성 입증 방법
				매니페스트 제공; 설치 전 관리자가 해시 대조 검증 절차 수립
	SI-10	물리적 변조 방지	*미적용*	SaMD 예외 — 독립형 소프트웨어로 하드웨어 기반 물리 변조 방지 구현 불가 (미적용 사유 참조)
	SI-11	부트 프로세스 무결성 검증	*미적용*	SI-11: SaMD 예외 — 독립형 소프트웨어로 부트 프로세스 무결성 검증 구현 불가 (미적용 사유 참조)
데이터 기밀성 (DC)	DC-01	정보에 대한 기밀성 보장	*적용*	src/lib/crypto.js — AES-256-GCM으로 환자 PII 필드 암호화 저장 (설치별 고유 256비트 키); 외부 전송 없음
	DC-02	보건의료정보 비식별화	*적용*	AdminBackup.jsx — 비식별 CSV 내보내기 기능 (이름·생년월일 제외한 데이터 내보내기)

사이버보안 요구사항			적용여부	적합성 입증 방법
	DC-03	안전한 암호화 사용	*적용*	AES-256-GCM (256비트), PBKDF2-SHA256 (256비트, 100,000회 반복), SHA-256 해시 — 모두 MFDS 권고 기준 충족
이벤트 적시 대응 (TRE)	TRE-01	감사로그에 대한 비인가된 접근 제한	*적용*	TRE-01: AdminAuditLog.jsx — admin 역할 전용 읽기 전용 뷰어; 수정·삭제 UI 없음 (추가 전용 로그)
자원 가용성 (RA)	RA-01	서비스 거부(Denial of Service, DoS) 방지	*미적용*	RA-01: 오프라인 단일 사용자 앱 — 네트워크 DoS 해당없음; 계정 잠금(IA-07)으로 무차별대입 방지 (미적용 사유 참조)
	RA-02	의료기기 백업	*적용*	RA-02: AdminBackup.jsx — AES-256-GCM 암호화 전체 백업; 정상 운영 중 언제든 백업 가능
	RA-03	의료기기 복구 및 재구성	*적용*	RA-03:

사이버보안 요구사항			적용여부	적합성 입증 방법
				AdminBackup.jsx — 복원 시 SHA-256 무결성 검증 후 데이터 복구
	RA-04	네트워크 및 보안 구성 설정	*미적용*	RA-04: 외부 네트워크 미사용 — 네트워크 보안 구성 기능 해당없음 (미적용 사유 참조)
	RA-05	불필요한 기능 비활성화	*적용*	외부 네트워크 미사용; allowMixedContent=false; 불필요한 Capacitor 플러그인 미등록; CSP로 외부 리소스 로드 제한

※ 의료기기의 사이버보안 요구사항 미적용 사유

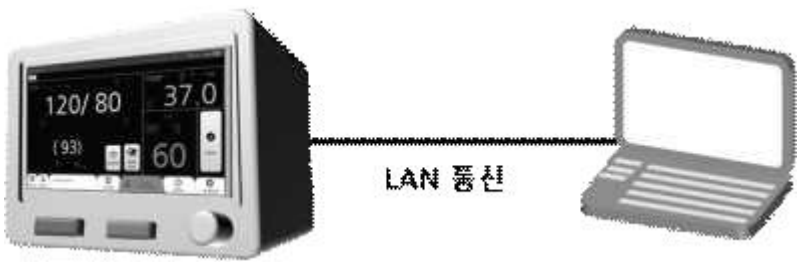
통신 무결성 보장 (SI-01) : 독립형 소프트웨어(SaMD)로서 외부 네트워크 통신 기능이 없으므로 해당 요구사항 제외 악성코드 보호 (SI-02) : 호스트 OS 및 브라우저 샌드박스 보안에 의존하며, 엔드포인트 보안은 병원 IT 정책 범위이므로 제외 자동화된 치료 보호 (SI-06) : 물리적 액추에이터나 자동 투약 등 실제 치료 프로세스에 직접 연결되지 않는 분석·훈련용 소프트웨어이므로 제외 물리적 변조 방지 (SI-10) : 하드웨어를 포함하지 않는 독립형 소프트웨어 형태의 의료기기로 하드웨어 기반의 변조 방지 요구사항 제외 부트 무결성 보호 (SI-11) : Android Verified Boot 등 하드웨어 및 OS 제조사의 책임 범위이며, 앱 레벨에서 구현할 수 없는 사항이므로 제외 서비스 거부 공격(DoS) 방지 (RA-01) : 완전 오프라인 단일 사용자 앱으로 네트워크를 통한 공격 경로가 없으므로 해당 요구사항 제외

네트워크 보안 구성 (RA-04) : 외부 네트워크를 사용하지 않으며, 기기 자체의 네트워크 설정은 병원 IT 관리 정책 범위에 해당하므로 제외

8. 시험기준 준수 명세

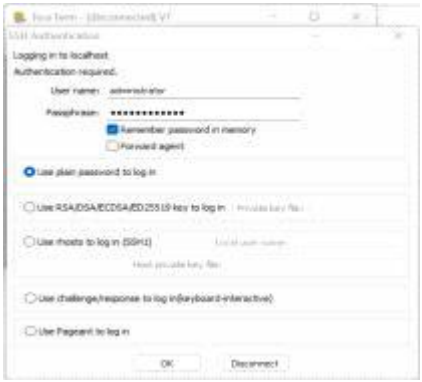
8.1. 식별 및 인증(IA, Identification and Authentication)

□ IA-01 사용자 식별 및 인증

구분	내용
세부 요구사항	- 사용자(사람, 소프트웨어, 기기)가 접근할 수 있는 모든 인터페이스마다 사용자를 식별하고 인증할 수 있는 기능이 있어야 한다. 이 기능은 상위 시스템의 식별 및 인증 시스템에서 제공하거나 의료기기에 자체적으로 구현할 수도 있다. * 접근할 수 있는 인터페이스 예: LAN, USB, WiFi 등 * 사용자 식별 및 인증은 다중 접속 금지 기능을 포함함 - 환자의 생명에 직접적인 영향을 미치는 의료기기와 통신하는 제품* 및 소프트웨어 의료기기(SaMD)의 경우 의료기기 자체적으로 사용자의 식별 및 인증 기능을 구현하는 것을 우선 고려해야 한다. * 예) 체외용인슐린주입기 등 약물을 주입하는 의료기기와 통신하는 모바일 의료용 앱, 이식형심장박동기·이식형심장충격기 등과 통신하는 심장박동기 분석기 및 모바일 의료용 앱 등
시험기준	다음 중 하나 이상 만족해야 하며, 식별 및 인증 기능이 정상 동작해야 한다. - 의료기기는 접근 가능한 각 인터페이스별로 사용자 식별 및 인증 기능을 구현한다. - 의료기기는 상위 시스템에서 제공하는 인증 기능을 이용할 수 있다. * 예) 아이디·비밀번호 기반 인증, 사전 공유키 또는 USB 토큰, 공유 계정
적용 예외사항	의료기기에 사용자가 접근 가능한 인터페이스가 없는 경우에는 적용하지 않는다.
시험방법 ***(예시)***	*1) 의료기기 설계 문서, 사용자 설명서 등에서 사용자를 확인한다.* *시험환경*  *2) 식별된 사용자가 접근 가능한 모든 인터페이스를 확인한다.* *- 시험대상에 LAN 연결 후 SSH 통신 도구를 이용하여 접근을 시도하고, 연결 시 아이디/비밀번호를 요청하는 것을 확인한다. 접근 대상에 OS 등이 설치되어 있을 경우 루트(Root) 계정 접근제어 기능이 존재하는지 확인한다.* ** 문서에 식별되지 않은 사용자가 접근 가능한지 인터페이스 점검*

□ IA-01 사용자 식별 및 인증

SSH 접근

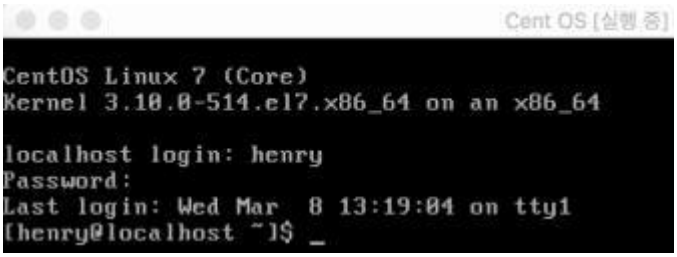


3) 식별된 인터페이스에 접근하여 접근제어 동작 여부를 확인한다.

- 시험환경 구축 후 의료기기에 접속 가능한 외부 인터페이스(예: 웹브라우저 등)를 실행하여 의료기기에 접속을 시도(예: 시험대상 URL 및 포트 정보 입력)

- 접속 시도 후, 아이디와 비밀번호로 식별 및 인증 수행 여부 확인

*비밀번호 입력 확인 예) QWer*1234*



□ IA-02 계정 관리

구분	내용
세부 요구사항	- 의료기기는 모든 계정을 관리할 수 있는 기능이 있거나, 계정을 관리하는 상위 시스템의 기능을 이용할 수 있어야 한다. - 인가된 사용자에 의해 모든 계정을 관리하는 기능(계정 추가, 활성, 수정, 비활성화 및 삭제 등)이 있어야 한다.
시험기준	다음 중 하나 이상 만족해야 하며, 계정 관리 기능이 정상 동작해야 한다. - 계정 관리 기능이 있다. - 상위 수준의 계정 관리 시스템을 이용할 수 있는 기능이 있다. * 상위 수준 계정 관리의 예: LDAP(Lightweight Directory Access Protocol), Active Directory 또는 호스트(예: 운영자 워크스테이션)에 연결된 의료기기 *** 필수 기능** - 의료기기는 상위 시스템에 가용성 문제가 발생한 경우에도 영향을 받지 않아야 한다. - 필수 기능에 사용되는 계정은 일시적으로라도 잠기지 않아야 한다.
적용 예외사항	의료기기에 고정된 관리자 계정이 하나만 구현되어 다른 계정을 추가할 수 없는 경우에는 적용하지 않는다.
시험방법	

□ IA-03 식별정보 관리

구분	내용
세부 요구사항	- 의료기기는 식별정보 관리 기능이 있는 시스템을 이용할 수 있거나, 직접적으로 식별정보를 관리할 수 있는 기능이 있어야 한다. - 계정 관리(IA-02)에 의해 생성된 계정은 각 계정을 명확하게 식별하기 위해 하나 이상의 유일한 식별정보를 사용한다. * 예) 식별정보 예: 계정 이름, 유닉스 사용자 ID, MS윈도우 계정 GUID(Globally unique identifiers), X.509 인증서 등
시험기준	다음 중 하나 이상 만족해야 하며, 식별정보 관리 기능이 정상 동작해야 한다. - 식별정보 관리기능이 있는 시스템을 이용하여 식별정보를 유일하고 모호하지 않게 관리한다. - 사용자, 그룹, 역할 또는 의료기기 인터페이스별로 식별정보를 유일하고 모호하지 않게 관리하는 기능이 있다. *** 필수 기능** - 필수 기능에 사용되는 계정은 일시적으로라도 잠기지 않아야 한다.
적용 예외사항	-
시험방법	

□ IA-04 인증정보 관리

구분	내용
세부 요구사항	- 초기 인증정보 방식을 사용할 수 있어야 한다. * 예) 토큰, 대칭키, 개인키(공개키/개인키 쌍의 부분), 생체 인식, 암호, 물리적 키 및 키 카드, 비밀번호 등 - 설치 후 디폴트 인증정보를 강제로 변경하거나, 디폴트 인증정보가 변경되지 않았을 경우 이를 알 수 있도록 기능이 있어야 한다. - 주기적으로 인증정보를 변경할 수 있는 기능이 있어야 한다. - 인증정보는 저장, 사용 및 전송 중에 공개되거나 변경되지 않아야 한다. *** 비밀번호 기반 의료기기인 경우 예시** - 관리자는 모든 신규 계정에 초기 비밀번호를 설정한다. 초기 비밀번호 설정은 공격자가 계정 생성과 처음 계정 사용(계정 소유자에 의한 신규 비밀번호 설정을 포함) 사이에 비밀번호 추측을 더 어렵게 만든다. - 설치 후 디폴트 비밀번호를 변경하도록 한다. - 주기적으로 비밀번호를 변경하거나 새로고침을 하도록 한다. 이때, 변경 주기를 명시해야 한다. - 비밀번호 전송을 요구하지 않는 핸드쉐이크 프로토콜 또는 암호화나 해싱 같은 암호기반 기능을 적용한다.
시험기준	다음 사항을 모두 만족해야 하며, 인증정보 관리 기능이 정상 동작해야 한다. - 의료기기 최초 접속 시 초기 인증정보 방식이 있다. - 설치 후 디폴트 인증정보를 강제로 변경하거나, 디폴트 인증정보가 변경되지 않았을 경우 경고 메시지 등으로 이를 알 수 있도록 한다. - 인증정보를 주기적으로 변경하도록 한다. - 인증정보를 저장, 사용, 전송할 때 인증정보가 공개되거나 변경되는 것으로부터 보호한다.
적용 예외사항	-
시험방법	

□ IA-05 비밀번호 강도 설정

구분	내용
세부 요구사항	비밀번호 기반 인증 기능이 있는 의료기기의 경우, 비밀번호 강도를 비밀번호 설정 지침에 따라 강제로 설정하는 기능이 있거나, 설정 기능이 있는 시스템을 이용할 수 있다.
시험기준	다음 중 하나 이상 만족해야 하며, 비밀번호 강도 설정 기능이 정상 동작해야 한다. - 비밀번호 설정 또는 변경 시 비밀번호 설정 지침(예: 정보통신망연결기기등 정보보호인증기준 상세 해설서)에 따른 비밀번호 강도를 적용한다. - 비밀번호 설정 지침을 적용한 강력한 외부 인증이 있는 시스템을 사용한다.
적용 예외사항	비밀번호 기반 인증 기능이 없는 의료기기의 경우 적용하지 않는다.
시험방법	

□ IA-06 인증정보에 대한 피드백

구분	내용
세부 요구사항	의료기기의 인증 기능이 있는 경우 인증 과정에서 인증정보에 대한 피드백은 명확하지 않아야 한다.
시험기준	비밀번호, 무선 키, 토큰을 마스킹(예: 별표(*)) 대신 일반 텍스트로 표시하지 않으며, 인증 피드백에 인증 실패 정보가 포함되지 않아야 한다. 예) "모르는 사용자 이름(unknown user name)" 같이 인증 실패 이유에 대한 힌트
적용 예외사항	의료기기의 인증 기능이 없는 경우 적용하지 않는다.
시험방법	

□ IA-07 연속적인 로그인 시도 실패 시 로그인 제한

구분	내용
세부 요구사항	의료기기의 인증 기능이 있는 경우 다음과 같은 기능이 있어야 한다. - 설정한 시간 동안 모든 사용자(사람, 소프트웨어, 기기)가 연속적으로 잘못된 접근을 시도하는 경우 로그인 시도 횟수를 제한해야 한다. - 이러한 횟수 제한에 도달했을 때 정해진 시간 동안 또는 관리자가 잠금 해제할 때까지 접근을 거부해야 한다. 관리자는 타임아웃이 만료되기 전에 계정을 잠금 해제할 수도 있다.
시험기준	다음 사항을 모두 만족해야 하며, 로그인 제한 기능이 정상 동작해야 한다. - 각 사용자 유형(사람, 소프트웨어, 기기)에 대해 설정된 시간 동안 연속적인 잘못된 접근 시도가 있는 경우 설정된 로그인 제한을 강제하는 기능이 있다. - 한도에 도달하면, 지정된 기간 동안 또는 잠금이 해제될 때까지 접근을 거부하는 기능이 있다. *** 필수 기능** - 필수 기능에 사용되는 계정은 일시적으로라도 잠기지 않아야 한다.
적용 예외사항	의료기기의 인증 기능이 없는 경우 적용하지 않는다.
시험방법	

□ IA-08 시스템 사용 알림 메시지

구분	내용
세부 요구사항	사용자(사람)가 의료기기의 사용자 인터페이스를 직접 조작할 수 있는 경우, 인증 과정에서 시스템 사용 알림 메시지를 보여주는 기능이 있어야 하며, 시스템 사용 알림 메시지는 인가된 직원에 의해 설정 가능해야 한다. *** 시스템 사용 알림 메시지 예시** 시스템 사용 알림 메시지는 개인이 의료기기에 로그인할 때 보이는 경고 배너 형식으로 구현될 수 있다. 다만, 원격 로그인 시 물리적으로 부착된 경고 배너는 적용할 수 없다. 시스템 사용 알림 메시지 예는 다음과 같다. - 개인 자산 소유자가 소유한 시스템에 접근함 - 시스템 사용은 모니터링, 기록 및 감사 대상이 될 수 있음 - 인가되지 않는 시스템 사용은 금지되고 민·형사 상의 처벌대상임 - 시스템의 사용은 모니터링과 기록에 동의함을 의미함
시험기준	다음 사항을 모두 만족해야 하며, 시스템 사용 알림 메시지 기능이 정상 동작해야 한다. - 인가된 사용자(사람)에 의해 시스템 사용 알림 메시지를 설정할 수 있는 기능이 있다. - 인증 과정 중 로컬 사용자(사람) 인터페이스를 통해 시스템 사용 알림 메시지를 표시하는 기능이 있다.
적용 예외사항	시스템에 대한 접근 기능이 없는 의료기기는 적용하지 않는다.
시험방법	

8.2. 사용 통제(UC, Use Control)

□ UC-01 권한 부여

구분	내용
세부 요구사항	의료기기는 부여된 책임(responsibility)에 따라 식별 및 인증된 모든 사용자에게 권한을 부여하는 기능이 있어야 한다.
시험기준	다음 사항을 모두 만족해야 하며, 권한 부여 기능이 정상 동작해야 한다. - 사용자(사람, 소프트웨어, 기기)의 식별 및 인증 기능이 있다. - 인증된 사용자에 대하여 권한과 역할이 정의되어 있다. - 권한 부여 시 최소권한을 적용하고, 부여된 권한에 따라 해당 기능에만 접근 및 사용 가능한지 확인한다.
적용 예외사항	의료기기에 고정된 관리자 계정이 하나만 구현되어 다른 계정을 추가할 수 없는 경우에는 적용하지 않는다.
시험방법	

□ UC-02 모바일 코드 사용 통제

구분	내용
세부 요구사항	의료기기가 모바일 코드 기술을 활용할 경우 의료기기는 모바일 코드 기술 사용에 관하여 최소한 다음과 같은 사용 통제 기능이 있어야 한다. - 모바일 코드 실행 통제 - 사용자(사람, 소프트웨어, 기기)가 모바일 코드 송수신 허용 통제 - 모바일 코드 실행 전에 무결성 점검의 결과를 기반으로 모바일 코드 실행 통제 *** 모바일 코드** - 수신자가 명시적으로 설치하지 않아도 실행되는 자산들 사이에 전송되는 프로그램 - JavaScript, VBScript, Java Applets, ActiveX 컨트롤, Flash 애니메이션, Shockwave 동영상 및 마이크로소프트 오피스 매크로 등이 있으며, 사용자의 별도 상호작용 없이 자동으로 다운로드 받은 환경에서 단독 실행되는 코드를 포함한다.
시험기준	다음 사항을 모두 만족해야 하며, 모바일 코드 사용 통제 기능이 정상 동작해야 한다. - 모바일 코드 사용에 대한 보안 정책을 시행할 수 있는 기능이 있다. - 모바일 코드의 실행을 제어한다. - 모바일 코드를 의료기기와 송수신하도록 허용하는 사용자를 정의한다. - 의료기기에 파일을 업로드만 하고, 모바일 코드 실행을 하지 않는다. - 모바일 코드 실행 전 무결성 검사를 수행한다.
적용 예외사항	의료기기가 모바일 코드 실행을 허용하지 않는 경우 적용하지 않는다.
시험방법	

□ UC-03 세션 잠금

구분	내용
세부 요구사항	로컬 또는 네트워크를 통해 의료기기에 사용자(사람)가 접속하는 경우, 의료기기는 다음과 같은 기능이 있어야 한다. - 설정 시간 동안 사용하지 않거나 사용자(사람, 소프트웨어, 기기)가 수동으로 시작하지 않으면 세션 잠금을 시작하여 추가 접근 방지 - 세션 잠금이 되면, 해당 세션을 사용하던 사용자(사람)이나 권한이 있는 다른 사용자(사람)가 적절한 로그인 절차를 통해 다시 접근하기 전까지 잠금 상태 유지
시험기준	로컬 또는 네트워크를 통한 모든 사용자 인터페이스에 대해 다음 사항 중 하나 이상을 만족해야 하며, 세션 잠금 기능이 정상 동작해야 한다. - 설정한 비활성 시간 후 세션을 잠금 한다. - 수동으로 세션을 잠금 한다. - 인증 절차를 통해서만 세션에 접근 가능하다. - 기본 인프라(운영체제, 의료기기 시스템)에서 요청한 세션 잠금을 준수한다. *** 필수 기능** - 세션 잠금 기능은 안전 기능에 부정적인 영향을 주지 않아야 한다. - 필수 기능에 사용되는 계정은 일시적으로라도 잠그지 않아야 한다.
적용 예외사항	- 로컬 또는 네트워크를 통해 의료기기에 대한 접속 기능을 제공하지 않는 경우 적용하지 않는다. - 세션 종료 기능이 있는 경우 세션 잠금 기능을 만족하는 것으로 한다.
시험방법	

□ UC-04 감사기록 생성

구분	내용
세부 요구사항	- 의료기기는 '접근통제, 요청 오류, 의료기기 이벤트, 백업 및 복구 이벤트, 설정 변경, 감사로그 이벤트'와 같은 보안 유형과 관련된 감사기록을 생성하는 기능이 있어야 한다. - 개별 감사기록은 타임스탬프, 출처, 카테고리, 유형, 이벤트 ID, 이벤트 결과와 같은 사항을 포함해야 한다.
시험기준	다음 사항을 모두 만족해야 하며, 감사기록 생성 기능이 정상 동작해야 한다. - 접근통제, 요청 오류, 의료기기 이벤트, 백업 및 복구 이벤트, 설정 변경, 감사로그 이벤트와 같은 보안 관련 유형에 대한 감사기록을 생성한다. - 감사기록에는 최소한 타임스탬프, 출처, 카테고리, 유형, 이벤트 ID, 이벤트 결과 등의 정보를 포함한다.
적용 예외사항	-
시험방법	

□ UC-05 감사 처리 실패 대응

구분	내용
세부 요구사항	- 감사 처리 실패 이벤트(소프트웨어/하드웨어 오류, 감사 추출 기능의 실패 및 감사 저장 용량 초과 등) 시 필수 서비스와 기능 손실에 대비하기 위한 기능이 있어야 한다. - 감사 처리 실패에 대응하여 적절한 작업을 지원하는 기능(예: 직원에게 알람, 메시지 등과 같은 수단을 통해 경고)이 있어야 한다.
시험기준	다음 중 하나 이상을 만족해야 하며, 감사 처리 실패 대응 기능이 정상 동작해야 한다. - 감사 처리 실패 시 필수 서비스 또는 기능의 손실이 없다. - 감사 처리 실패에 대한 적절한 조치를 한다.
적용 예외사항	-
시험방법	

□ UC-06 타임스탬프

구분	내용
세부 요구사항	의료기기는 감사기록에서 사용하는 타임스탬프(날짜 및 시간 포함) 생성 기능이 있어야 한다.
시험기준	다음 사항을 모두 만족해야 하며, 타임스탬프 기능이 정상 동작해야 한다. - 감사기록에 대한 타임스탬프 생성 기능이 있다.(UC-04 참조) - 타임스탬프에는 날짜와 시간을 포함한다.
적용 예외사항	-
시험방법	

□ UC-07 부인 방지

구분	내용
세부 요구사항	의료기기에 사용자(사람) 인터페이스가 있는 경우, 해당 사용자(사람)가 특정 행동을 했는지 여부를 판단하는 기능이 있어야 한다. * **사용자의 특정 행동의 예시** 사용자(사람) 작업 수행, 의료기기 설정 변경, 정보 생성, 메시지 전송, 정보 승인(동의 표시 같은) 및 메시지 수신 등 * **부인 방지 서비스를 위한 기술 및 기능 예시** 사용자 식별 및 인가, 전자서명, 디지털 메시지 수신 및 타임스탬프
시험기준	다음 사항을 모두 만족해야 하며, 부인 방지 기능이 정상 동작해야 한다. - 사용자의 특정 행동에 대해 감사기록을 생성한다. - 감사기록에 사용자를 식별할 수 있는 정보를 포함한다. *** 필수 기능** - 부인 방지는 필수 기능에 상당한 지연을 주지 않아야 한다.
적용 예외사항	의료기기에 사용자(사람) 인터페이스가 없는 경우 적용하지 않는다.
시험방법	

8.3. 시스템 무결성(SI, System Integrity)

□ SI-01 통신에 대한 무결성 보장

구분	내용
세부 요구사항	의료기기는 전송된 정보의 무결성을 보호하는 기능이 있어야 한다.
시험기준	다음 중 하나 이상을 만족해야 하며, 전송된 정보의 무결성 보호 기능이 정상 동작해야 한다. - 표준화된 암호화 프로토콜을 사용한다. - 권장 프로토콜(예: KS X IEC 62443-4-2 CR 4.3에 언급된 기타 예시)을 사용한다. (DC-03 참조)
적용 예외사항	-
시험방법	

□ SI-02 악성코드로부터 보호

구분	내용
세부 요구사항	- 소프트웨어 의료기기(SaMD)에 적용: 소프트웨어 의료기기(SaMD) 제조자는 해당 의료기기(SaMD 포함)와 호환되는 악성코드 방지 기능을 확인하고 문서화하며, 악성코드 방지를 위해 필요한 설정이나 조건이 있는 경우 이를 기록해야 한다. * 악성코드로부터의 보호는 외부 서비스, 애플리케이션에 의해 제공될 수도 있다. - SaMD 이외 의료기기에 적용: 의료기기는 인가되지 않은 소프트웨어(악성코드를 포함할 수 있음)의 설치 및 실행으로부터 보호하는 기능이 있어야 한다. *** 악성코드의 예시** 바이러스, 웜, 트로이 목마, 스파이웨어 등
시험기준	1) 소프트웨어 의료기기(SaMD)인 경우 사용자 설명서에 보호 기능을 구현하는 호환 가능한 보안 기능이 하나 이상 기재되어 있으며, 정의된 악성코드 대응 기능을 통해 의료기기를 보호해야 한다. 2) SaMD 이외 의료기기인 경우 다음 중 하나 이상을 만족해야 하며, 정의된 악성코드 대응 기능을 통해 의료기기를 보호해야 한다. - 승인되지 않은 소프트웨어의 설치 및 실행으로부터 보호할 수 있는 기능이 있다. - 운영환경에서 악성코드 보호 기능이 있는 경우 적용한다. - 허용된 탐지 기술을 사용한다: 바이너리 무결성, 속성 모니터링, 해싱, 서명 기술 - 허용된 방지 기술을 사용한다: 이동식 미디어 제어, 샌드박스 기술, 특정 컴퓨팅 플랫폼 기능(예: 제한된 펌웨어 업데이트), 실행 금지(NX) 비트, 데이터 실행 방지(DEP), 주소 공간 레이아웃 무작위화(ASLR)*, 스택 손상 탐지, 필수 접근통제, 프로세스 화이트리스트 및 이와 유사한 기능 포함 * ASLR(Address space layout randomization): 실행시마다 메모리 주소를 변경시켜 악성코드에 의한 특정주소 호출 방지
적용 예외사항	-
시험방법	

□ SI-03 보안 기능 검증

구분	내용
세부 요구사항	의료기기는 보안 기능의 의도된 작동을 검증하는 기능이 있어야 한다. *** 보안 기능 검증의 예시** - 유럽 컴퓨터 백신 연구소(EICAR, European Institute for Computer Antivirus Research)에서 제공하는 테스트 파일을 의료기기 파일 시스템에서 검사하여 백신 프로그램이 이 테스트 파일을 탐지하고, 적절한 사고 대응 절차가 실행되는지 확인해야 한다. - 무단 계정으로 접근 시도를 통해 식별, 인증 및 사용 제어 방어책이 제대로 작동하는지 확인해야 한다. 일부 기능은 자동화하여 시험할 수 있다. - 침입탐지시스템(IDS, Intrusion Detection System)에 알려진 비악성 트래픽에 대한 규칙을 추가하여, 이 규칙에 따라 트래픽이 발생할 때 IDS가 이를 감지하고 적절한 모니터링 및 사고 대응 절차가 실행되는지 확인해야 한다. - 보안 정책과 절차에 따라 감사 로그가 기록되고 있으며, 내부 또는 외부 요인에 의해 비활성화되지 않았는지 확인해야 한다. *** IEC 62443-3-3 SR 3.3 요구사항** 의료기기는 FAT(Factory Acceptance Testing), SAT(Site Acceptance Testing) 및 예정된 유지보수 중에 이상 징후가 발견될 경우 보안 기능의 의도된 작동을 확인하는 기능을 제공해야 한다. 이러한 보안 기능은 동 표준에 명시된 보안요구사항을 지원하는데 필요한 모든 것이 포함되어야 한다.
시험기준	다음 사항을 모두 만족해야 하며, 보안 기능 검증 기능이 정상 동작해야 한다. - 보안 기능 검증을 위한 자동 또는 수동 검증 절차를 정의하고 있다. - 의료기기의 보안 기능 검증 절차에 따라 보안 기능에 대해 검증할 수 있는지 확인한다. - 의료기기의 보안 기능 동작에 따른 결과(성공, 실패)에 대해 생성된 감사기록을 통해 보안 기능이 정상 동작여부를 알 수 있는지 확인한다.
적용 예외사항	-
시험방법	

□ SI-04 소프트웨어 및 정보에 대한 무결성 점검

구분	내용
세부 요구사항	의료기기는 소프트웨어, 정보에 대한 무결성 점검 기능(무결성 점검 수행 또는 지원, 점검 결과 기록)이 있거나, 무결성 점검을 수행 또는 지원할 수 있는 시스템 기능을 이용할 수 있어야 한다.
시험기준	다음 중 하나 이상을 만족해야 하며, 무결성 점검 기능이 정상 동작해야 한다. - 저장 데이터(예: 보안 설정, 설정, 펌웨어 구성 및 기타 정보)에 대해 무결성 점검을 수행한다. - 무결성 검사를 수행하거나 지원할 수 있는 시스템을 이용할 수 있다.
적용 예외사항	-
시험방법	

□ SI-05 입력값 검증

구분	내용
세부 요구사항	의료기기는 의료기기의 동작에 직접 영향을 미치는 외부 인터페이스를 통한 입력이나, 의료기기 제어 입력으로 사용된 모든 입력 데이터의 구문, 길이 및 내용을 검증해야 한다. *** 입력값 검증 항목** - 정의된 필드 유형에 범위를 벗어난 값의 유효성을 검증한다. - 데이터 필드에 유효하지 않은 문자를 검증한다. - 누락되거나 불완전한 데이터 및 버퍼 오버플로를 검증한다. - SQL 삽입 공격을 검증한다. - 크로스사이트스크립트를 검증한다. - 잘못된(malformed) 패킷을 검증한다.
시험기준	의료기기의 동작에 직접적인 영향을 미치는 모든 입력의 구문 및 내용에 대한 유효성 검사를 수행하고 정상 동작하는지 확인해야 한다.
적용 예외사항	-
시험방법	

□ SI-06 오류 시 사전 결정된 상태로 출력

구분	내용
세부 요구사항	자동화 프로세스와 연결된 의료기기는 제조자가 정의한 정상 작업을 유지할 수 없다면 사전 결정된 상태로 출력하는 기능이 있어야 한다. *** 자동화 프로세스와 연결된 의료기기 예시** - 생체신호를 실시간으로 모니터링하고 이상 징후 감지 시 알람을 출력하는 환자 감시장치 - 약물을 일정한 속도로 주입하는 체외용인슐린주입기 *** 사전 결정된 상태 예시** - 의료기기에 오류 발생으로 정상 동작을 할 수 없는 경우 어떻게 동작할지에 대해 미리 정해놓은 설정 상태 - 예: 체외용인슐린주입기의 사전 결정된 상태로 '인슐린 주입 중단 및 사용자 알람 발생'으로 설정한 경우, 제품 오류 발생 시 즉시 인슐린 주입을 중단하고 사용자에게 알람을 울리도록 하여 사용자가 수동으로 인슐린을 주입할 수 있게 조치함
시험기준	다음 사항을 모두 만족해야 하며, 사전 결정된 상태로 출력하는 기능이 정상 동작해야 한다. - 사전 결정된 상태의 출력에 대해 문서화한다. - 제조자가 정의한 정상 작업 상태가 아닌 안전모드(예: 장애 시 안전(fail safe))로 실행되는 경우, 사전 결정된 상태로 동작한다. *** 장애 시 안전(Fail safe, TTA정보통신용어사전)** - 회선, 기기, 시스템 등이 고장이나 오동작에 대비하여 구조적으로 안전하게 설계되어 있거나 이중 안전장치를 갖추고 있어서 절대 안전하다는 것을 의미하는 말. 예를 들어 장애 시 안전 시스템(fail-safe system)이라고 하면, 그 시스템의 일부분에 장애가 발생하거나 심각한 오작동이 발생해도 프로그램이나 데이터의 분실, 파손을 야기하지 않고 동작을 계속할 수 있도록 설계된 컴퓨터 시스템을 말한다. - 조작자의 실수나 오작동 또는 고장 등에 대비한 자동 안전 장치
적용 예외사항	의료기기가 자동화 프로세스와 연결되지 않는 경우 적용하지 않는다.
시험방법	

□ SI-07 오류 처리

구분	내용
세부 요구사항	의료기기는 의료기기 또는 의료용 IT네트워크를 공격하는 공격자에 의해 악용될 수 있는 정보를 제공하지 않는 방식으로 오류 조건을 식별하고 처리해야 한다. *** 공격자에게 도움을 줄 수 있는 오류 메시지의 예시** 인증의 실패 원인에 대한 상세 정보를 제공하는 것으로, 올바르지 않은 사용자 ID나 올바르지 않은 비밀번호를 제시하는 피드백은 공격자가 의료기기를 공격하는데 도움을 줄 수 있다.
시험기준	오류 조건을 식별하고 처리하며, 오류 발생 시 중요정보가 유출되지 않아야 한다.
적용 예외사항	-
시험방법	

□ SI-08 업데이트

구분	내용
세부 요구사항	의료기기는 업데이트 또는 업그레이드 기능이 있어야 한다.
시험기준	업데이트 또는 업그레이드할 수 있는 기능이 있어야 하며, 필수 기능에 영향을 주지 않고 패치 및 업데이트가 진행되어야 한다.
적용 예외사항	-
시험방법	

□ SI-09 업데이트에 대한 진본성 및 무결성 검증

구분	내용
세부 요구사항	의료기기는 설치 전에 소프트웨어 업데이트 또는 업그레이드의 진본성과 무결성을 검증해야 한다.
시험기준	시험항목 SI-08와 연계하여 업데이트 또는 업그레이드 파일 설치 전에 진본성 및 무결성을 확인하고 이상이 없을 때만 설치되어야 한다.
적용 예외사항	-
시험방법	

□ SI-10 물리적 변조 방지

구분	내용
세부 요구사항	의료기기는 인가되지 않은 물리적 접근을 방지하기 위해 물리적 변조 방지 기능(예: 잠금장치, 캡슐화, 보안 나사(비표준 헤드 유형))이 있어야 한다.
시험기준	불필요한 외부 인터페이스에 물리적 변조 방지 기능이 있어야 한다.
적용 예외사항	소프트웨어 의료기기(SaMD)에는 적용하지 않는다.
시험방법	

□ SI-11 부트 프로세스 무결성 검증

구분	내용
세부 요구사항	의료기기는 사용하기 전에 의료기기의 부트와 런타임 프로세스에 필요한 펌웨어, 소프트웨어 및 설정 데이터의 무결성을 검증해야 한다. *** 부트 프로세스 무결성 보충 설명** 악의적인 공격자가 의료기기, 자산 또는 데이터에 접근할 수 있는 안전하지 않거나 유효하지 않은 운영 상태로 부트되지 않음을 보장하기 위해, 의료기기는 부트 프로세스 동안 의료기기의 펌웨어, 소프트웨어 및 설정 데이터의 무결성 검증을 수행해야 한다.
시험기준	사용 전 부트 프로세스 관련 펌웨어, 소프트웨어 및 설정 데이터에 대한 무결성 검증 기능이 정상 동작해야 한다.
적용 예외사항	소프트웨어 의료기기(SaMD)에는 적용하지 않는다.
시험방법	

8.4. 데이터 기밀성(DC, Data Confidentiality)

□ DC-01 정보에 대한 기밀성 보장

구분	내용
세부 요구사항	의료기기는 읽기 권한이 지원되는 저장 정보의 기밀성 보호 기능과 전송 중 정보의 기밀성 보호 기능이 있어야 한다.
시험기준	다음 사항을 모두 만족해야 하며, 정보에 대한 기밀성 보장 기능이 정상 동작해야 한다. - 도청이나 우연한 노출을 통한 정보의 무단 공개로부터 보호하는 기능이 있다. - 읽기 권한이 지원되는 미사용 정보의 기밀성을 보호하는 기능이 있다. - 전송 중인 정보의 기밀성을 보호한다. - 암호화 통신(프로토콜)을 사용한다. - 오래되었거나 더 이상 사용되지 않는 프로토콜을 사용하지 않는다 - 추가 보호 기능(예: 암호화 서명)이 없는 평문 프로토콜(예: FTP)을 사용하지 않는다.
적용 예외사항	-
시험방법	

□ DC-02 보건의료정보 비식별화

구분	내용
세부 요구사항	의료기기에 저장된 보건의료정보를 통해 권한이 없는 사람이 환자를 식별할 수 있는 경우, 해당 정보를 비식별화할 수 있는 기능(예: 애플리케이션 소프트웨어, 추가 도구 등)이 있어야 한다. *** 참고사항** 승인된 사용자만 접근할 수 있는 가명화 및 환자 식별 키를 사용하면, 승인된 사용자만 보건의료정보를 재식별할 수 있다.
시험기준	보건의료정보 비식별화 기능을 통해 환자 식별정보를 알 수 없어야 한다.
적용 예외사항	의료기기가 개인식별정보를 저장하지 않는 경우 적용하지 않는다.
시험방법	

□ DC-03 안전한 암호화 사용

구분	내용
세부 요구사항	암호화가 필요한 경우, 의료기기는 국내·외에서 권고하는 암호학적 보안 기능을 사용해야 하며, 사용하는 암호화 키는 안전하게 관리해야 한다. *** 보충 설명** 암호학적 보호 적용 대상은 저장 정보나 전송 중 정보, 또는 양쪽 모두를 포함할 수 있다. 의료기기 공급자는 암호키 설정 및 관리와 관련된 사례와 절차를 문서화해야 한다. - AES, SHA 같은 검증된 암호 및 해시 알고리즘을 사용해야 한다. ※ 비밀번호는 Salt 값을 갖는 일방향 해시 알고리즘 적용 권고 - 표준 기반 키 길이(key size)를 활용해야 한다. - 키 생성은 효율적인 난수 생성기를 사용하여 수행해야 한다. - 키 관리의 보안 정책 및 절차는 정의된 표준에 따라 주기적인 키 변경, 키 폐기, 키 배포 및 암호키 백업을 다룰 필요가 있다.
시험기준	다음 사항을 모두 만족해야 한다. - 표준화된 암호 알고리즘을 사용한다. - 권장 프로토콜(예: KS X IEC 62443-4-2 CR 4.3에 언급된 기타 예시)을 사용한다.
적용 예외사항	-
시험방법	

8.5. 이벤트 적시 대응(TRE, Timely Response to Events)

□ TRE-01 감사로그에 대한 비인가된 접근 제한

구분	내용
세부 요구사항	의료기기는 인가된 사용자만 읽기 전용으로 감사로그에 접근할 수 있다.
시험기준	권한이 있는 사용자만 읽기 전용으로 감사로그에 접근할 수 있어야 하며, 수정할 수 있는 기능이 없어야 한다.
적용 예외사항	-
시험방법	

8.6. 자원 가용성(RA, Resource Availability)

□ RA-01 서비스 거부(Denial of Service, DoS) 방지

구분	내용
세부 요구사항	- 의료기기는 DoS 이벤트 중에도 필수 기능을 유지하는 기능이 있어야 한다. - DDoS의 경우 공용 네트워크망에 접속하여 의료기기를 실시간으로 제어 또는 환자 생명과 직접적으로 연관될 수 있는 정보를 실시간으로 송수신하는 장비에 적용하고, DDoS 공격에 대한 대응책이 수립되어야 한다.
시험기준	DoS 이벤트가 발생하는 동안 필수 기능이 정상 동작해야 한다.
적용 예외사항	-
시험방법	

□ RA-02 의료기기 백업

구분	내용
세부 요구사항	의료기기는 백업 기능이 있어야 하며, 백업 프로세스는 정상적인 의료기기 작동에 영향을 미치지 않아야 한다.
시험기준	다음 사항을 모두 만족해야 한다. - 의료기기에 대한 백업 기능이 정상 동작해야 한다. - 백업 프로세스가 정상 작동에 영향을 미치지 않는다. - 백업 정보에 암호키 등 보호가 필요한 정보를 포함하는 경우, 민감한 데이터 암호화, 민감한 정보 제외 등과 같은 보호 기능이 정상 동작해야 한다.
적용 예외사항	-
시험방법	

□ RA-03 의료기기 복구 및 재구성

구분	내용
세부 요구사항	의료기기는 중단 또는 장애 상황 발생 후 안전한 상태로 복구 및 재구성하는 기능이 있어야 한다.
시험기준	중단 또는 장애 후 보안 상태로 복구 및 재구성하는 기능이 있어야 하며, 다음 사항을 모두 만족해야 한다. - 시스템 매개변수(기본값 또는 설정 가능)는 안전한 상태로 구성할 수 있는 값으로 설정한다. - 보안에 중요한 패치가 다시 설치된다. - 보안 관련 구성 설정이 다시 설정된다. - 사용자 설명서 및 운영 절차를 사용할 수 있다. - 의료기기가 다시 설치되고 기존 설정으로 구성된다. - 권한 있는 사용자에 의해 선택한 백업 또는 인증된 백업을 사용하여 복구한다.
적용 예외사항	-
시험방법	

□ RA-04 네트워크 및 보안 구성 설정

구분	내용
세부 요구사항	의료기기는 사용자 설명서에서 권고하는 네트워크와 보안 구성에 따른 설정 기능과 인터페이스가 있어야 하며, 구성 설정 변경을 모니터링하고 통제할 수 있어야 한다.
시험기준	다음 사항을 모두 만족해야 한다. - 사용자 설명서에 네트워크 및 보안 구성에 따른 설정 기능과 인터페이스에 대한 설명이 있으며, 해당 내용에 따라 네트워크 및 보안 구성을 설정할 수 있다. - 네트워크 및 보안 구성 설정 변경에 대한 모니터링 기능이 정상 동작한다.
적용 예외사항	-
시험방법	

□ RA-05 불필요한 기능 비활성화

구분	내용
세부 요구사항	의료기기는 불필요한 기능, 포트, 프로토콜, 서비스의 사용을 제한하는 기능(기본 구성 설정 이외의 기능은 비활성화)이 있어야 한다.
시험기준	불필요한 기능, 포트, 프로토콜 또는 서비스의 사용을 제한하는 기능이 정상 동작해야 한다.
적용 예외사항	-
시험방법	